ABC TECH
INFORMATION SECURITY, DATA PROTECTION AND IT OPERATIONS POLICY

Organization: Northstar Digital Services Pvt. Ltd.
Policy ID: NS-ISP-001
Version: 1.0
Policy Owner: Chief Information Security Officer (CISO)
Approved By: Executive Management
Effective Date: 1 October 2026
Review Frequency: Annually and following significant security or regulatory changes
Classification: Internal
Status: Sample policy for compliance testing

1. Purpose

Northstar Digital Services Pvt. Ltd. establishes this Information Security, Data Protection and IT Operations Policy to protect its information assets, business applications, infrastructure, employee information, customer information and confidential business records against unauthorized access, disclosure, alteration, loss and destruction.

This policy defines the minimum security and privacy requirements applicable to employees, contractors, consultants, service providers and other authorized parties who access organizational systems or process information on behalf of the organization.

The organization intends to establish and maintain security practices that support applicable legal and contractual obligations and relevant control requirements from ISO/IEC 27001, SOC 2, PCI DSS where payment card data is in scope, and India's Digital Personal Data Protection Act, 2023, where applicable.

The policy establishes requirements for access management, data classification, encryption, monitoring, incident response, vulnerability management, business continuity, supplier security, privacy, retention and secure disposal.

2. Scope

This policy applies to:

All employees, temporary workers, contractors and third-party personnel with access to organizational information.

Production, development, testing and staging environments.

Cloud infrastructure, servers, endpoints, databases, networks and business applications.

Customer personal data, employee personal data, financial records, credentials, source code, security logs and confidential business information.

Physical and electronic records created, received, processed, stored or transmitted by the organization.

Third-party platforms and service providers that store or process organizational information.

Payment card data and the systems that store, process or transmit it, where the organization participates in a payment card environment.

System owners must identify the assets and business processes covered by this policy. Any exclusions must be documented, justified, risk-assessed and approved by the appropriate authority.

3. Governance and Responsibilities

3.1 Executive Management

Executive management shall approve this policy, assign security responsibilities, provide appropriate resources and review significant information security risks.

Management shall review material incidents, significant audit findings, unresolved high-risk vulnerabilities and exceptions that could affect the organization's legal, contractual or business obligations.

3.2 Chief Information Security Officer

The CISO shall maintain the information security program, coordinate risk assessments, establish security standards, oversee incident response and monitor the resolution of security findings.

The CISO shall review this policy at least annually and whenever material changes occur in business operations, technology, applicable obligations or the threat environment.

3.3 System Owners

System owners shall maintain an inventory of their systems, identify the information processed by those systems, approve access requests and ensure that applicable security requirements are implemented.

System owners shall periodically review user access, investigate control failures and retain records demonstrating that required activities have been completed.

3.4 Employees and Contractors

Personnel shall protect organizational information, use approved systems, maintain credential confidentiality, complete required security training and promptly report suspected security incidents.

Personnel shall not bypass security controls, share individual accounts, install unauthorized software or transfer confidential information to unapproved services.

4. Information Asset Inventory and Classification

The organization shall maintain an inventory of important information assets, including hardware, software, cloud services, databases, business applications, datasets and information repositories.

Each asset shall have an assigned owner responsible for maintaining its inventory details, classification, business purpose and security requirements.

Information shall be classified into the following categories:

Public: Information approved for unrestricted public distribution.

Internal: Information intended for normal business use that should not be disclosed externally without authorization.

Confidential: Customer information, employee records, business contracts, financial information, internal investigations and other information requiring restricted access.

Restricted: Highly sensitive information, including authentication secrets, cryptographic keys, payment card data where applicable, privileged credentials

and especially sensitive personal information.

Information owners shall determine appropriate access, storage, transmission, retention and disposal requirements based on classification, contractual commitments and applicable law.

Confidential and restricted information shall not be placed in publicly accessible repositories or transferred through unapproved channels.

5. Identity and Access Management

Access to organizational systems shall follow the principles of least privilege and need to know. Users shall receive only the permissions necessary to perform their assigned responsibilities.

Every user shall have a uniquely identifiable account wherever technically feasible. Shared accounts shall be restricted to approved technical circumstances and shall have compensating controls that preserve accountability.

Access requests must identify the requester, intended user, required permissions, business justification, target system and approving authority. Access shall not be granted until the required approval is recorded.

Multi-factor authentication shall be required for privileged accounts, remote access and other systems identified as high risk. Strong authentication mechanisms shall be implemented according to the organization's authentication standard.

Privileged access shall be limited to designated administrators. Administrative activities shall be logged, and privileged accounts shall not be used for routine work when a standard account is available.

Managers and system owners shall review access rights at least quarterly for critical systems and at least semiannually for other in-scope systems. Reviews shall identify excessive permissions, inactive accounts, unauthorized access and incompatible duties.

Access shall be revoked promptly when employment or a contract ends. Role changes shall trigger a review of existing permissions so that obsolete access is removed.

Authentication secrets shall be stored securely using approved password hashing or secret-management mechanisms. Credentials and API keys shall not be embedded in source code, committed to public repositories or stored in plain-text configuration files.

6. Data Protection and Encryption

Confidential and restricted information shall be protected against unauthorized disclosure, alteration and loss throughout its lifecycle.

Sensitive information transmitted over untrusted networks shall use approved encrypted communication protocols. Databases, storage systems, endpoints and backups containing sensitive information shall use encryption appropriate to their risk and regulatory requirements.

Cryptographic keys shall be managed separately from the protected data where appropriate. Key access shall be restricted to authorized personnel, and key creation, distribution, rotation, revocation and destruction shall follow documented procedures.

Production credentials shall be stored in an approved secrets-management system or equivalent protected mechanism. Access to secrets shall be logged where supported, and exposed credentials shall be revoked or rotated promptly.

Sensitive information shall not be copied into development or testing environments unless authorized and protected by appropriate safeguards. Masking, tokenization or synthetic test data shall be used when suitable.

Data transfers to external parties shall be approved, use secure transmission methods and be limited to the information necessary for the authorized business purpose.

7. Privacy and Personal Data Processing

The organization shall identify the purposes for which personal data is collected, used, disclosed, retained and deleted. Personal data shall be processed only for authorized purposes and in accordance with applicable legal requirements and documented business needs.

The organization shall identify its responsibilities as a Data Fiduciary, Data Processor or equivalent contractual role, as applicable to each processing activity.

Before introducing a new service or materially changing a processing activity, the responsible business owner shall assess privacy risks, data categories, intended purposes, access requirements, third-party involvement and retention needs.

Where required, appropriate notices, consents or other legally valid grounds for processing shall be established. Requests from individuals concerning their personal data shall be handled through a documented process with identity verification, appropriate authorization and response tracking.

Personal data shall not be collected merely because it may be useful in the future. Collection and processing shall be limited to what is reasonably necessary for the documented purpose.

The organization shall maintain appropriate records of personal data processing and applicable disclosures. Cross-border transfers, disclosures to service providers and onward processing shall be assessed against applicable legal requirements and contractual restrictions.

When personal data is no longer required for its lawful purpose, and no legal, regulatory or contractual retention obligation applies, it shall be securely deleted or anonymized as appropriate.

The organization shall maintain a process to identify and respond to personal data breaches, including assessment of notification and communication obligations under applicable law.

8. Logging, Monitoring and Audit Trails

Critical systems shall generate logs sufficient to support security monitoring, troubleshooting, investigation and accountability.

Depending on the system, log records shall include authentication attempts, successful and failed logins, privilege changes, administrative operations, access to sensitive records, configuration changes, security events and relevant data export or deletion activities.

Logs shall include timestamps, system or service identifiers, relevant actor identifiers, event types, outcomes and other contextual information necessary to investigate an event.

System clocks shall be synchronized with approved time sources where technically feasible.

Access to logs shall be restricted to authorized personnel. Logs shall be protected against unauthorized modification and deletion through appropriate permissions, centralized collection, access monitoring or tamper-resistant storage.

The organization shall establish retention periods for security and audit logs based on risk, business requirements and applicable obligations. Logs shall not be retained indefinitely without a documented justification.

Security alerts shall be reviewed according to their severity. High-priority alerts shall be escalated to the designated security personnel, and investigations shall document the event, actions taken, findings and closure approval.

Audit records supporting regulated activities shall be retained in accordance with the applicable retention schedule and shall not be removed merely to conceal an incident, control failure or unauthorized action.

9. Vulnerability and Patch Management

The organization shall identify vulnerabilities affecting its operating systems, applications, dependencies, cloud services, network devices and other in-scope assets.

Vulnerability identification shall use appropriate methods, including security advisories, authenticated scanning, dependency analysis, configuration reviews, penetration testing and vendor notifications.

Each identified vulnerability shall be assessed based on severity, exploitability, exposure, asset criticality, business impact and available remediation measures.

Critical vulnerabilities affecting exposed or sensitive systems shall receive immediate attention and expedited remediation according to the approved response standard. Other vulnerabilities shall be assigned remediation deadlines based on their assessed risk.

Where a vulnerability cannot be remediated within the required timeframe, the system owner shall document the reason, assess the residual risk, implement compensating measures and obtain formal risk acceptance from an authorized approver.

Security testing shall be performed before significant production releases where appropriate. Findings shall be tracked until remediation is verified or a formally approved exception is recorded.

Unsupported software and operating systems shall be replaced, upgraded or isolated using documented risk controls.

10. Secure Development and Change Management

Changes to production systems, infrastructure, databases, security configurations and application code shall follow a documented change-management process.

Change requests shall describe the purpose, scope, affected assets, risk assessment, testing approach, implementation plan and rollback procedure.

Changes shall receive appropriate review and approval before implementation. Emergency changes may use an expedited approval process, but the justification, implementation details and retrospective review shall be documented.

Development, testing and production environments shall be separated according to system risk. Production access shall be restricted and monitored.

Code changes shall undergo appropriate peer review, automated testing and security checks before release. Dependencies shall be assessed for known vulnerabilities, and secrets shall be excluded from source code repositories.

Database schema changes affecting evidence, control mappings, AI assessments or audit history shall be managed through version-controlled migrations. Migrations shall be tested against a representative test environment and include a recovery or rollback plan where feasible.

Production deployment records shall identify the change, responsible personnel, deployment time, validation results and any post-deployment issues.

11. Incident Response and Breach Management

The organization shall maintain a documented incident-response process covering identification, reporting, classification, containment, investigation, recovery and post-incident review.

Personnel shall report suspected incidents promptly through approved reporting channels. Examples include compromised credentials, malware, unauthorized access, lost devices, exposed personal data, unexpected deletion of records and suspicious system activity.

Security personnel shall record each incident in an incident register and assign a severity level based on impact, scope, data sensitivity, service disruption and potential legal consequences.

The response team shall preserve relevant evidence, restrict further unauthorized access and coordinate containment actions. Investigations shall record timestamps, affected assets, known indicators, actions taken, decisions and responsible personnel.

Where personal data or regulated information is involved, the organization shall assess applicable notification obligations, contractual requirements and deadlines. Required notifications shall be approved by authorized personnel and issued through appropriate channels.

Recovery activities shall include verification that affected systems are safe to restore, access credentials are secure, vulnerabilities are addressed and critical data remains accurate.

Following a significant incident, the organization shall conduct a post-incident review to identify root causes, evaluate response effectiveness and assign corrective actions. Corrective actions shall have accountable owners and target completion dates.

12. Backup, Recovery and Business Continuity

Critical business systems and data shall be backed up according to documented recovery requirements.

Backup schedules shall reflect the criticality of the data, acceptable data-loss tolerance and recovery-time objectives established by business owners.

Backups containing confidential or restricted information shall be protected against unauthorized access and encrypted where appropriate. Access to backup repositories shall be restricted separately from ordinary production access where feasible.

Backup copies shall be protected against ransomware, accidental deletion and unauthorized modification through appropriate isolation, immutability or offline storage mechanisms where justified by risk.

Recovery procedures shall be documented and tested periodically. Testing shall verify that selected backups can be restored, that recovered data is usable and that the process meets the intended recovery objectives.

Business continuity and disaster recovery plans shall identify critical services, recovery dependencies, responsible personnel, communication channels and escalation procedures.

Test results and identified recovery gaps shall be documented. Failures shall result in corrective actions with assigned owners and deadlines.

13. Third-Party and Supplier Security

Third parties that access organizational systems or process organizational information shall undergo a risk assessment proportionate to the sensitivity of the information and criticality of the service.

Supplier assessments shall consider access permissions, data handling practices, security certifications or assurance reports where relevant, incident history, subcontractors, data location, continuity arrangements and termination procedures.

Contracts shall include appropriate confidentiality, security, data protection, incident reporting, data return or deletion and audit or assurance provisions, where applicable.

Supplier access shall be limited to the systems and information required for the approved service. Access shall be reviewed periodically and removed when no longer required.

Material changes in supplier services, ownership, processing locations or security posture shall trigger a reassessment where appropriate.

At contract termination, the organization shall recover its information and credentials, revoke access and obtain confirmation of data return or deletion where contractually required and technically feasible.

14. Data Retention and Secure Deletion

The organization shall maintain a documented retention schedule identifying relevant information categories, business purposes, owners, retention periods and authorized disposal methods.

Retention periods shall be established based on applicable legal requirements, contractual obligations, operational needs, security investigations and documented business purposes.

When the retention period expires and no valid hold or other retention requirement applies, information shall be securely deleted or irreversibly anonymized using a method appropriate to its storage medium and sensitivity.

Deletion shall cover relevant primary records, redundant copies and derived datasets where feasible. Backups shall follow documented expiry and rotation procedures, and deleted information shall not be restored to normal use without applying the applicable deletion requirements.

Cloud services and third-party repositories shall be included in deletion procedures where the organization controls or contracts for the relevant data.

Deletion of a record in an application database shall not be treated as proof that all copies have been removed. The organization shall define and document how associated files, database records, derived extracts and backups are handled.

Where information must be retained for legal, regulatory, contractual or investigation purposes, the retention exception shall be documented and access restricted.

Deletion activities involving sensitive information shall be recorded where appropriate. Records should identify the information category, responsible system, execution time, method and verification result without unnecessarily reproducing the sensitive information itself.

15. Payment Card Data Security

This section applies only to systems and business processes within the organization's applicable payment card data environment.

Where payment card data is processed, stored or transmitted, the organization shall identify the applicable scope and establish controls appropriate to PCI DSS requirements and its contractual responsibilities.

Payment card data shall be collected only where necessary for an authorized transaction. Sensitive authentication data shall not be retained after authorization where prohibited by applicable PCI DSS requirements.

Stored cardholder data shall be minimized and protected using permitted methods. Transmission shall use approved secure protocols. Access shall be limited to authorized personnel with a documented business need.

Systems within scope shall be subject to appropriate network security controls, vulnerability management, secure configuration, access monitoring, logging and security testing.

The organization shall document the systems and service providers within scope and periodically reassess whether system changes have affected the payment card environment.

Evidence of applicable controls shall be maintained for assessment and verification. This policy alone does not establish PCI DSS compliance.

16. Security Awareness and Training

All personnel shall receive security awareness training during onboarding and periodically thereafter.

Training shall cover phishing, credential protection, data classification, acceptable use, secure handling of personal data, incident reporting, remote work security and relevant role-specific responsibilities.

Personnel with privileged access or specialized security responsibilities shall receive additional training appropriate to their duties.

Completion records shall be retained, and overdue training shall be followed up by the responsible manager.

The organization may conduct simulated phishing exercises or other awareness activities. Results shall be used to improve training and reduce risk rather than replace technical safeguards.

17. Risk Assessment and Control Monitoring

The organization shall maintain a documented information security risk assessment process. Identified risks shall be evaluated based on likelihood, impact, existing safeguards and residual exposure.

Each material risk shall have an assigned owner and an appropriate treatment decision: mitigate, avoid, transfer or accept.

Risk acceptance shall identify the business justification, residual risk, approving authority and review or expiry date where applicable.

Control owners shall maintain evidence demonstrating how applicable controls operate. Evidence may include approved policies, access review records, system configurations, incident tickets, vulnerability reports, backup test results, change approvals and training records.

The organization shall periodically assess control design and operating effectiveness. Identified deficiencies shall be recorded, prioritized and tracked through corrective action.

Management shall review significant risks, overdue remediation, audit findings and recurring control failures. Changes to the risk environment shall inform future assessments and policy updates.

18. Policy Exceptions

Exceptions to this policy require a documented business justification, identification of affected systems and information, risk assessment, compensating controls and approval from an authorized risk owner.

Exceptions shall have a defined validity period and review date. Permanent exceptions shall not be granted without formal review and appropriate management approval.

The CISO or designated security authority may require an exception to be withdrawn if risk increases, compensating controls fail or applicable obligations change.

All exceptions shall be recorded in an exception register and reviewed periodically.

19. Enforcement

Violations of this policy may result in access restrictions, mandatory corrective actions, disciplinary action or contractual remedies, subject to applicable law and organizational procedures.

Suspected violations shall be investigated fairly and documented appropriately. Evidence related to investigations shall be preserved and access restricted to authorized personnel.

No employee or contractor shall intentionally alter or delete security records to conceal unauthorized activity, bypass approved controls or interfere with a legitimate investigation.

20. Policy Review and Approval

The CISO shall review this policy annually and after material changes in organizational operations, technology, threat exposure or applicable requirements.

Proposed changes shall be reviewed by relevant stakeholders and approved by authorized management. The current approved version shall be published in the designated policy repository, and superseded versions shall be retained according to the document-retention schedule.

All personnel within scope shall be informed of material policy changes and any training obligations arising from them.

Approval Record

Policy Owner: Chief Information Security Officer
Management Approver: Authorized Executive
Approval Date: To be completed
Next Review Date: To be completed
Document Repository: To be completed